Gobierno de la Ciberseguridad y Análisis de Riesgos

Tema 1. La seguridad de la información en las organizaciones

Índice

Esquema

Ideas clave

1.1. Objetivos

1.2. Introducción

1.3. La seguridad de la información implica la confidencialidad, integridad y disponibilidad

1.4. La seguridad es un asunto económico

1.5. La seguridad es un proceso

1.6. La clasificación de la información

1.7. La seguridad se articula con controles de seguridad

1.8. La seguridad en la información implica la gestión de los riesgos

1.9. La seguridad es tanto física como lógica

1.10. La seguridad implica a las personas

1.11. Referencias bibliográficas.

A fondo

Economía de la seguridad de la información

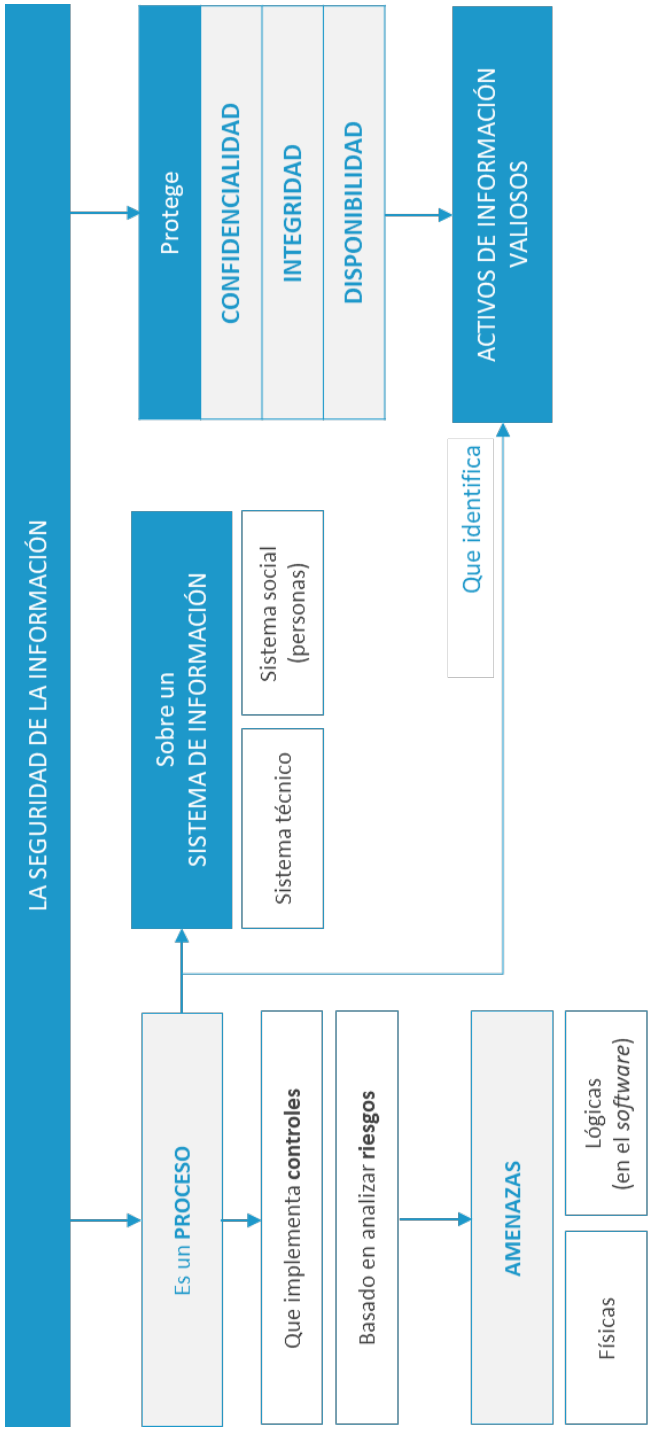
Social Engineering Fundamentals

¿Por qué la seguridad de la información es difícil?

Historia secreta de los primeros hackers – informática

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

1.1. Objetivos

El objetivo fundamental de esta unidad es el de comprender la seguridad de la información como una actividad orientada a **garantizar la confidencialidad, integridad y disponibilidad** de los recursos valiosos de un **sistema de información.**

Concretamente se espera que al finalizar el tema seas capaz de:

- Dar ejemplos y describir **amenazas** y situaciones en las que no se garantiza la confidencialidad, integridad y/o disponibilidad de recursos de información.
- Explicar por qué la **seguridad de la información** debe considerarse como un **proceso** y no como un producto.
- Enunciar y explicar los **aspectos económicos** fundamentales de la seguridad de la información.
- Describir y dar ejemplo de los diferentes **tipos de amenazas y controles** para la seguridad física.
- Describir la importancia y el papel de la **gestión de riesgos** en la seguridad de la información.
- Diferenciar y dar ejemplos de las diferentes **herramientas de gestión** para la seguridad de la información.
- Describir la importancia del factor humano en la seguridad de la información, definir las técnicas de **ingeniería social** y dar ejemplos de estas.

© Universidad Internacional de La Rioja (UNIR)

1.2. Introducción

Se introduce el **concepto de la seguridad en la información** como un **proceso para eliminar los riesgos** asociados a la confidencialidad, integridad y disponibilidad de uno de los recursos empresariales más valiosos: la información.

Para comenzar el tema, debes leer el **caso de estudio** y consultar las fuentes mencionadas en él para comprender la perspectiva de la seguridad de la información desde el punto de vista de la empresa. Es particularmente interesante buscar información de estimaciones de coste de incidentes o brechas de seguridad que han sido notorias en los medios.

Finalmente, la pregunta fundamental en la gestión es si el coste de la no seguridad es mayor que el de la seguridad. Dicho de otra forma, **la gestión de la seguridad tiene que fundamentarse en un análisis coste-beneficio.** El problema es que la cuantificación del coste en este caso depende del análisis de riesgos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El tema debe comenzarse comprendiendo y sabiendo enunciar:

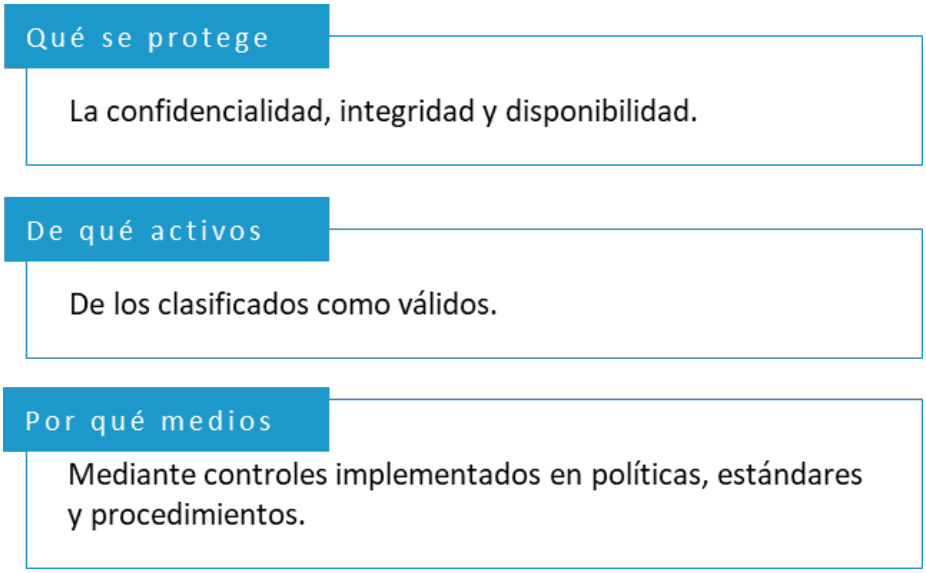


Figura 1. Conceptos fundamentales a la hora de hablar de la gestión de la seguridad. Fuente: elaboración propia.

Además de lo anterior, es importante conocer la **protección de las amenazas físicas.**

También como aspecto general de gran importancia debes comprender la importancia del **factor humano** y entender que las **técnicas de ingeniería social** hacen inútiles a los medios técnicos más sofisticados. Es interesante buscar y leer casos de brechas de seguridad en las que el eslabón más débil fue un empleado y no un sistema pobremente configurado.

© Universidad Internacional de La Rioja (UNIR)

1.3. La seguridad de la información implica la confidencialidad, integridad y disponibilidad

Hablar de **seguridad de información** es mucho más que tratar sobre cómo configurar *firewalls,* aplicar parches para corregir nuevas vulnerabilidades en el sistema operativo o guardar de forma cuidadosa los *backups.*

La seguridad de la información implica determinar qué hay que proteger y por qué, de qué se debe proteger y cómo protegerlo.

Los términos *seguridad de la información* y *seguridad informática* se utilizan con frecuencia como sinónimos, aunque no describen exactamente lo mismo. En general, l a **seguridad de la información** *(information security)* hace referencia a la confidencialidad, integridad y disponibilidad de la información, independientemente del medio en que se almacenen los datos.

La información se almacena en diferentes soportes, pueden ser electrónicos, impresos o de otro tipo. Por otro lado, la seguridad de la información implica la implementación de estrategias que cubran los **procesos de la organización** en los cuales la información es el activo primordial. En contraposición, «seguridad informática» es un concepto más restrictivo que caracteriza la seguridad técnica de los sistemas informáticos.

© Universidad Internacional de La Rioja (UNIR)

La seguridad en la empresa

Un sistema informático seguro puede incluir técnicas sofisticadas de criptografía, detección de intrusos y seguimiento de la actividad interna. No obstante, la simple negligencia de un empleado relativa a la política de claves de seguridad puede permitir el acceso a un intruso. Es importante entender que un sistema de seguridad incluye también a personas y procedimientos más allá de los sistemas informáticos en sí.

En palabras de Bruce Schneier, «si piensas que la tecnología puede solucionar tus problemas de seguridad, eso quiere decir que no comprendes los problemas y que no comprendes la tecnología».

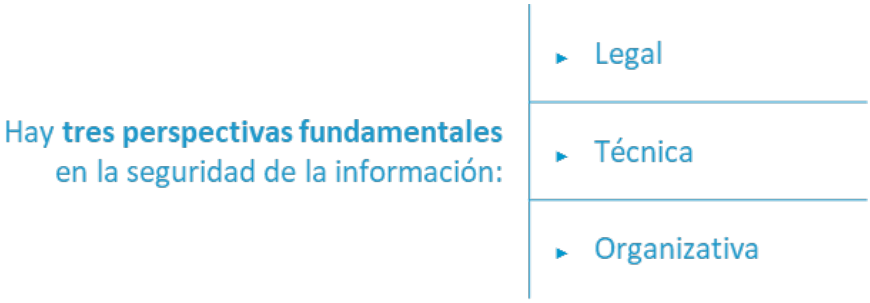


Figura 2. Perspectivas fundamentales en la seguridad de la información. Fuente: elaboración propia.

El **punto de vista legal** concierne a las regulaciones internacionales, nacionales y regionales que protegen básicamente la privacidad y los derechos de propiedad intelectual.

La **perspectiva técnica** es la del desarrollo, análisis, configuración y despliegue de elementos técnicos (*hardware, software,* redes) que tiene determinadas características relacionadas con la seguridad.

Finalmente, la **visión organizativa** considera esencialmente la seguridad como un elemento fundamental para el negocio, dado que permite asegurar que los procesos

© Universidad Internacional de La Rioja (UNIR)

de negocio se realizan sin disrupciones en cuanto a la confidencialidad, disponibilidad e integridad de la información. La perspectiva organizativa de la seguridad se basa en el **análisis de riesgos,** dado que el coste de las brechas o ataques contra la seguridad es un elemento para evitar de difícil estimación. Esto incluye también los riesgos legales, dado que en la mayoría de las empresas se guarda información personal, al menos, de los clientes.

Podemos decir que la perspectiva organizativa y la legal indican **qué hay que proteger** (lo establecido en la ley y los recursos importantes para la organización), **por qué** y **de qué** (porque se protegen derechos de las personas frente a violaciones de la privacidad o porque comprometer ciertos recursos de información afecta al negocio por acciones de robo de información o espionaje industrial).

La perspectiva técnica se encarga del **cómo** hay que proteger desde el punto de vista técnico (por ejemplo, si hay que utilizar ciertas actualizaciones de un sistema operativo, si hay que desplegar *honeypots* o instalar un IDS) dependiendo de la tipología cambiante de las amenazas (por ejemplo, la difusión generalizada de los *smartphones* requiere medidas adicionales para este tipo de plataformas).

La seguridad de la información en una organización básicamente implica la protección de los activos necesarios para que la organización cumpla con su misión frente al daño o la destrucción. Por esa naturaleza, es **una actividad crítica en la empresa.** Dado que no puede conseguirse un nivel perfecto de seguridad, la decisión del grado de seguridad (y el coste que se incurre en obtenerla) es una decisión básica de gestión.

Desgraciadamente, en muchas ocasiones los usuarios perciben las medidas de seguridad como controles innecesarios, engorrosos o excesivos. Por ello, los controles de seguridad deben justificarse adecuadamente y la actitud de los empleados hacia la seguridad debe ser objeto de formación, entrenamiento y explicación.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La seguridad es un proceso continuo de mejora y no un estado de un sistema, por lo que las políticas y controles establecidos para la protección de la información deberán revisarse, probarse y adecuarse, de ser necesario, ante los nuevos riesgos que se identifiquen.

En este sentido, se puede decir que **no existe un sistema de información perfectamente seguro,** dado que las amenazas evolucionan y también la propia organización y sus recursos de información. No obstante, dependiendo de los procesos relacionados con la seguridad, será más o menos fácil que se produzca una violación o brecha de seguridad y también ésta tendrá más o menos impacto y será más o menos costosa de paliar.

La seguridad de la información se suele conceptualizar en torno a tres principios principales ya mencionados: confidencialidad, integridad y disponibilidad.

Un sistema de información es un conjunto de **componentes interrelacionados** que recogen, almacenan, procesan y distribuyen información para dar soporte a la toma de decisiones y el control dentro de una organización.

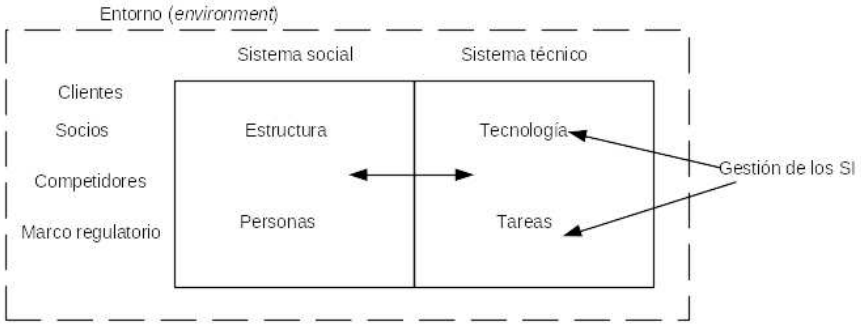
Los componentes incluyen *software* y *hardware* pero también procedimientos, estructuras organizativas y otros elementos. Hay que diferenciarlo del sistema informático. Para estudiarlos, se debe utilizar una aproximación socio técnica.

© Universidad Internacional de La Rioja (UNIR)

Aclaración

Un **sistema de información** es un conjunto de componentes interrelacionados que recogen, almacenan, procesan y distribuyen información para dar soporte a la toma de decisiones y el control dentro de una organización.

Los componentes incluyen *software* y *hardware*, pero también procedimientos, estructuras organizativas y otros elementos. Hay que diferenciarlo de «sistema informático». Para estudiarlos, se debe utilizar una aproximación «socio-técnica».



Por tanto, la gestión de la seguridad de los Sistemas de Información cubren todos los elementos que aparecen en la anterior figura. Para saber más sobre conceptos de sistemas de información puede consultarse el libro de Laudon&Laudon:

Pearson. Laudon, K. C. y Laudon. J . P. (2004). *Sistemas de información gerencial* (10ª ed.). México: Pearson- Prentice Hall.

Figura 3. Gestión de los sistemas de información en el entorno organizativo. Fuente: elaboración propia.

Por tanto, la gestión de la seguridad de los sistemas de información cubre todos los elementos que aparecen en la anterior figura.

Para saber más sobre conceptos de sistemas de información puede consultarse el libro de Laudon y Laudon: Laudon, K. C. y Laudon, J. P. (2004) *Sistemas de información gerencial* (10.ª ed.). Pearson-Prentice Hall.

La seguridad de la información se suele conceptualizar en torno a tres principios principales ya mencionados: **confidencialidad, integridad y disponibilidad.** A continuación, se describe cada uno de ellos.

© Universidad Internacional de La Rioja (UNIR)

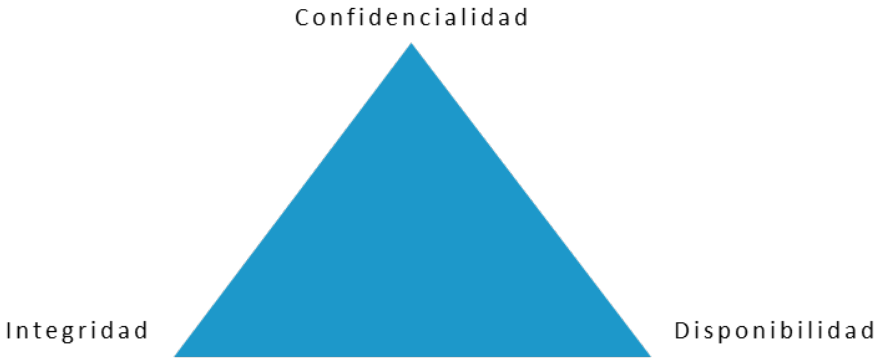


Figura 4. Los tres principios generales de la seguridad de la información. Fuente: elaboración propia.

Estos tres atributos pueden utilizarse como criterio para los controles de seguridad dentro de las organizaciones. Sus atributos opuestos, de carácter negativo o no deseable, son la revelación, la alteración y la destrucción.

La confidencialidad

La **privacidad** es quizá el aspecto que **se menciona con más frecuencia** en cuanto a la confidencialidad. La privacidad de la información personal es un derecho protegido por regulaciones internacionales y nacionales, pero no es más que una de las caras de la confidencialidad.

En una empresa, la lista de los mejores proveedores en un área no es información personal, pero obviamente su acceso debe estar limitado a ciertos empleados.

Pensemos como otro ejemplo en el código fuente de una aplicación informática desarrollada en una empresa para su venta, ese código no debería revelarse y debería estar estrictamente protegido. En otros casos, la confidencialidad está asociada a otras restricciones externas. Por ejemplo, los planes de defensa por su naturaleza deben clasificarse como confidenciales.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La confidencialidad es la propiedad de prevenir la relación y divulgación intencionada o no intencionada de información a personas o sistemas no autorizados.

Las amenazas a la confidencialidad son múltiples y los medios para conseguir acceso muy diversos. Una alternativa es la ingeniería social, que aprovecha el factor humano para hacerse con información confidencial, pero también muchos troyanos tienen como objeto extraer información confidencial de manera automática, por ejemplo.

© Universidad Internacional de La Rioja (UNIR)

Un ejemplo de técnica para obtener información confidencial es el conocido *phishing*

Con el auge de las redes sociales online como Facebook también ha llegado el *phishing* especializado en estas redes. El ejemplo que se muestra debajo es un mensaje de correo electrónico que aparentemente es una invitación a hacer un contacto en Facebook. A pesar de que hay signos para reconocer que es fraudulento (como el dominio *aol.com* del remitente), muchos usuarios caían en la trampa. En este caso, el fraude permitiría acceder a la información privada de nuestra cuenta de Facebook.

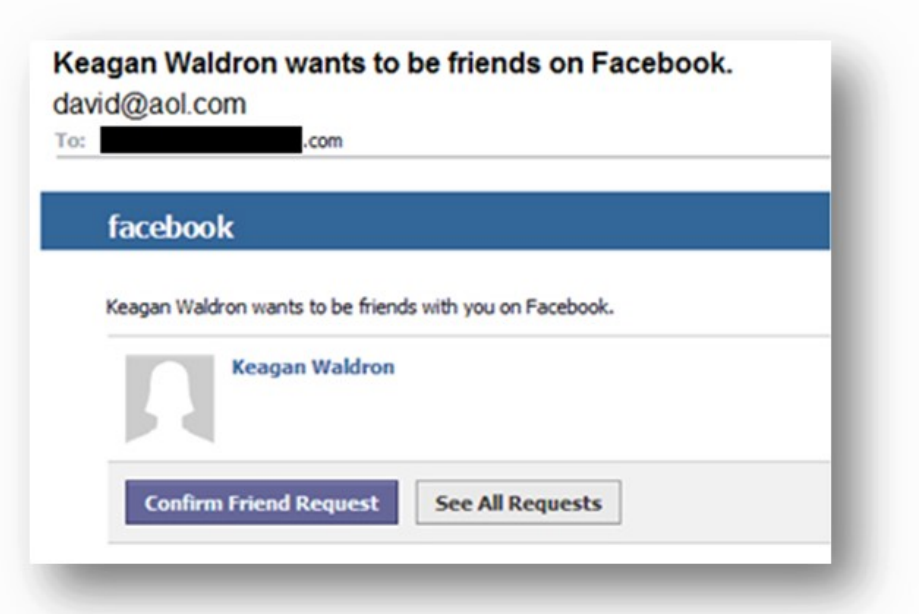


Figura 5. Correo electrónico que simula una solicitud de amistad en Facebook. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

La integridad

Quizá el ejemplo más típico de ataque contra la integridad sea la alteración de un balance de una cuenta bancaria. Los ataques contra la integridad suelen implicar también pérdidas de confidencialidad, pero no necesariamente.

En ocasiones, el intruso o persona no autorizada no modifica la información directamente, sino que modifica alguno de los programas que la actualizan. De este modo, incluso sin conocer el saldo de una cuenta bancaria, se puede reducir su cuantía mediante la alteración deliberada del software, bien del programa en sí o del proceso en ejecución del programa.

La integridad del apropiado buscará mantener los datos libres de modificaciones no autorizadas.

Algunos autores consideran que la integridad debe también cubrir las modificaciones no autorizadas por el personal autorizado, es decir, el control interno de las autorizaciones.

La integridad de la información se gestiona de acuerdo con tres principios básicos:

- Dar acceso de acuerdo con el criterio del menor privilegio (criterio *need-to-know*).
- Separación de obligaciones *(duties).*
- Rotación de obligaciones.

El primero de los principios es muy simple. Solo se debe dar acceso a los usuarios a aquellos recursos de información que les sean absolutamente imprescindibles para realizar su trabajo. Yendo un paso más allá, este principio lleva a establecer controles específicos para evitar que los usuarios puedan modificar información de maneras que comprometan su integridad. Un ejemplo de este tipo de controles es un registro de transacciones de las acciones del usuario, de modo que puedan

© Universidad Internacional de La Rioja (UNIR)

inspeccionarse posteriormente.

> Análisis estático
>
> El análisis de código estadístico es un conjunto de técnicas que analiza el código de la aplicación para buscar vulnerabilidades. Las técnicas de *taint analysis* tratan de explorar cómo los valores de entrada de la interfaz de usuario de una aplicación se utilizan en el código para modificar los datos. Este análisis estático es un ejemplo de control relacionado con la integridad.

El segundo de los principios implica que, para una determinada tarea, no haya nunca un solo usuario responsable de realizarla. De esta manera, al menos habrá dos personas implicadas y será más difícil que se utilice una manipulación de datos para beneficio personal. El tercero de los principios va en la misma dirección y propone que las tareas asignadas a los empleados cambien de responsable de vez en cuando. El problema con la rotación es que, en empresas con pocos empleados en un determinado tipo de puesto, puede ser difícil el intercambiar sus tareas.

La disponibilidad

Un sistema está disponible cuando sus usuarios legítimos pueden utilizarlo para realizar funciones legítimas. Es decir, para realizar el trabajo necesario para el negocio.

La disponibilidad es la característica, cualidad o condición de la información de encontrarse a disposición de quienes deben acceder a ella como usuarios autorizados, ya sean personas, procesos o aplicaciones.

© Universidad Internacional de La Rioja (UNIR)

En el contexto de la seguridad de la información, habitualmente se habla de la disponibilidad en dos situaciones típicas:

- Ataques de denegación de servicio *(Denial of Service, DoS).*
- Pérdidas de datos o capacidades de procesamiento de datos debidas a catástrofes naturales (terremotos, inundaciones, etc.) o a acciones humanas (bombas, sabotajes, etc.).

Los ataques *DoS* se han hecho populares en la web a través de los medios de comunicación. Un **ataque *DoS*** sobre un sistema es básicamente un ataque por el cual los recursos de cómputo del sistema se redirigen por medios externos a tareas que **impiden su uso por los usuarios legítimos.**

Estos ataques frecuentemente se realizan mediante la **infección previa** de otros equipos en la red sin el conocimiento de sus propietarios de modo que se coordinan para solicitar el servicio de un determinado sitio web (como ocurre con las *botnets*).

Las pérdidas de datos por catástrofes naturales pueden parecer a muchas empresas posibilidades remotas, por lo que en ocasiones tienden a subestimarse. Este tipo de catástrofes o eventos sobrevenidos son el objeto de los **planes de contingencia.**

Un ejemplo son los sitios alternativos de proceso, que permiten continuar la operación del negocio transfiriendo a otra infraestructura física alternativa. En el terreno técnico, los avances en la **computación tolerante a fallos** son mecanismos que usualmente combinan *hardware* y *software* para asegurar la disponibilidad.

Otros conceptos previos importantes

Además de la tríada que acabamos de describir, hay otros conceptos básicos importantes que se deben tener en cuenta en la gestión de la seguridad y que conviene recordar en este momento. La siguiente tabla los resume:

© Universidad Internacional de La Rioja (UNIR)

Concepto	Definición	Ejemplo
Sistemas de identificación	Medios por los que los usuarios reclaman su identidad.	El medio más conocido es la identificación mediante usuario y clave
Autentificación	La evaluación de la evidencia de la identidad de un usuario.	La comprobación de la contraseña introducida con la almacenada en el sistema.
Rendición de cuentas *(accountability)*	La capacidad de un sistema de atribuir cada acción realizada a un usuario determinado.	Los sistemas de auditoría y las bitácoras *(logs)* cumplen esta función.
Autorización	Los derechos y permisos asignados a un individuo con respecto a los recursos del sistema.	Derechos de lectura o escritura sobre determinados ficheros
Privacidad	Nivel de confidencialidad dado a los usuarios de un sistema.	La forma y grado en que los usuarios de una red social pueden ver los datos de los demás usuarios

Tabla 1. Otros conceptos relevantes a la hora de hablar de la gestión de la seguridad en la organización.

Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

1.4. La seguridad es un asunto económico

En muchas empresas no se toma suficientemente en cuenta la seguridad de la información hasta que experimentan un ataque o una brecha de seguridad. Y una vez que el evento indeseado sucede, es cuando comienza la consideración económica.

Dado que la seguridad cuesta dinero, el problema fundamental es buscar un **equilibrio** entre el **coste de la seguridad** y el **impacto económico de los riesgos probables.** Es importante entender la vertiente económica de la seguridad, dado que aparentemente los avances técnicos en seguridad (como lo fue la criptografía en su día) no mejoran la seguridad de las empresas si éstas no la **ponen en práctica.** La criptografía, siguiendo el ejemplo, se convierte en un arma matemática inútil si los empleados no cumplen con la política de elección y custodia de sus claves.

En general, la seguridad implica costes incluso más allá del coste de los sistemas, *software* o tiempo de expertos en la configuración y diseño de estos. También tiene un coste en la forma de la resistencia de los empleados o su frustración, que en ocasiones ven las medidas de seguridad como impedimentos para realizar su trabajo más ágilmente.

En el caso del desarrollo de aplicaciones, un *software* bien protegido es más caro y requiere más tiempo de desarrollo que uno que no lo esté. Por otro lado, solo las intrusiones con un efecto importante tienen un impacto económico considerable y rara vez han llegado históricamente a llevar al cierre de operaciones de la empresa. Esto hace que racionalmente muchas empresas no dediquen grandes esfuerzos a la seguridad.

© Universidad Internacional de La Rioja (UNIR)

Por eso, muchas tecnologías de seguridad comienzan a utilizarse cuando se dan los dos siguientes elementos:

- Son fáciles de implantar.
- Los auditores de seguridad comienzan a demandarlas.

Este es el caso por ejemplo de los *firewalls.* El coste de implantarlos se ha reducido considerablemente porque cada vez son más fáciles de implantar, hay más gente preparada para hacerlo y, por otro lado, el coste de no tenerlos, en el caso de una auditoría, es grande (la empresa no pasará la auditoría).

El aspecto económico de la seguridad es tan importante que es un campo de estudio en sí mismo: *Information Security Economics.* Tyler Moore y Roose Anderson elaboran informes técnicos con los avances en esta área que merece la pena conocer.

Un marco económico para la seguridad de la información

Adrián Mizzi ha elaborado un marco conceptual para responder a la pregunta que se hacen tantas empresas sobre si están invirtiendo mucho o poco en seguridad de la información. Básicamente, este marco permite estimar el retorno de la inversión en seguridad de la información (ROSI), si bien la estimación de las variables es compleja por lo elusiva de la medición de las amenazas y las vulnerabilidades. El siguiente gráfico resume el marco conceptual.

© Universidad Internacional de La Rioja (UNIR)

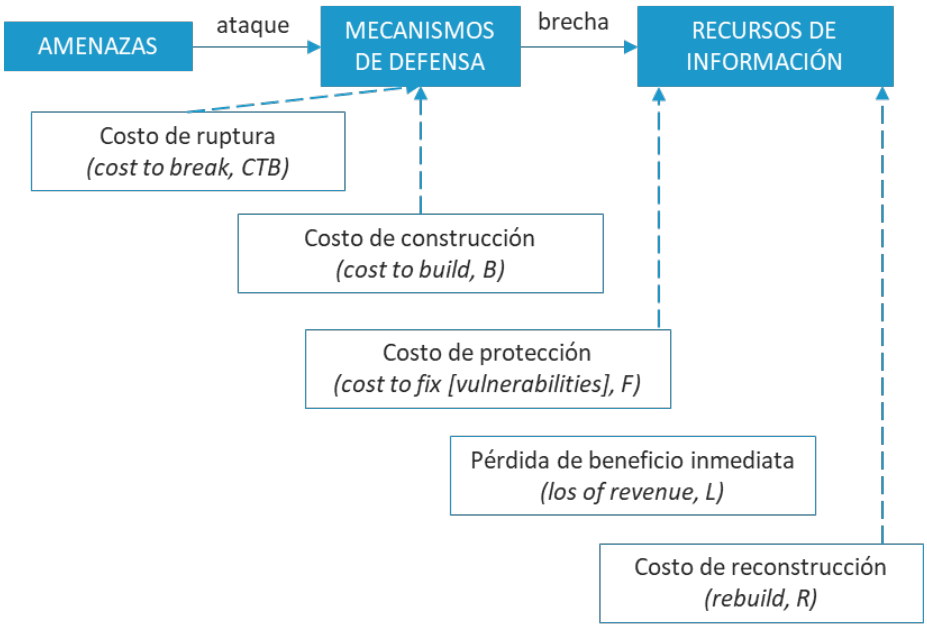


Figura 6. Marco conceptual para la estimación del retorno de la inversión en seguridad de la información (ROSI). Fuente: adaptado de Mizzi 2010.

La idea es que hay unos costes, tanto desde el punto de vista del ataque como del de la defensa, y posterior mitigación del daño. Los atacantes se enfrentan a medidas de defensa explícitas y a la identificación de vulnerabilidades.

En general para que un atacante incurra en este coste de ruptura, o CTB, los beneficios de su acción tienen que ser superiores. El problema en este lado es doble:

- Por un lado, los beneficios de los ataques son difíciles de estimar a priori, pero en general, si se pretende vender información confidencial, por ejemplo, para el fraude de tarjetas de crédito, en general el coste de explorar las vulnerabilidades es bajo en relación con el beneficio posible. Solo cuando los mecanismos de protección sean más complejos de burlar, el atacante no lo seguirá intentando.

© Universidad Internacional de La Rioja (UNIR)

- Por otro lado, los motivos de los atacantes son subjetivos, e incluyen motivaciones no económicas, que los pueden llevar a incurrir en CTB mayores que los beneficios económicos esperados (que en ocasiones es ninguno simplemente). La estimación del CTB puede hacerse mediante la contratación de un *penetration testing,* donde se contratan servicios de profesionales que intentan realizar un ataque en condiciones realistas.

Del lado de la organización, los dos costes básicos son:

- **Coste de construcción de las medidas defensivas,** incluyendo la configuración de firewalls, sistemas redundantes, IDS, etc.

- **Coste de reparación de vulnerabilidades:** en una configuración simple, esto puede consistir en mantener el software actualizado con los últimos parches, pero en ocasiones esto no es suficiente, y hace falta un esfuerzo proactivo en buscar vulnerabilidades potenciales según aparecen.

Metasploit mantiene una base de datos de *exploits no* (descripciones de secuencias de acciones o módulos *software* que permiten aprovechar una vulnerabilidad para conseguir un comportamiento no deseado de un sistema) que pueden buscarse online en este vínculo: https://www.metasploir.com/modules/

© Universidad Internacional de La Rioja (UNIR)

Comprobación de vulnerabilidades con Metasploit

Una política de reparación de vulnerabilidades proactiva puede incluir la búsqueda de este tipo de herramientas para comprobar vulnerabilidades en los sistemas a medida que aparecen.

Si tenemos una PYME que ha decidido utilizar el sistema de CRM de código abierto SugarCRM, podemos encontrar la vulnerabilidad que se detalla en la siguiente captura de pantalla. Metasploit ofrece código, muestras de ejecución y documentación completa para la reparación de la vulnerabilidad.

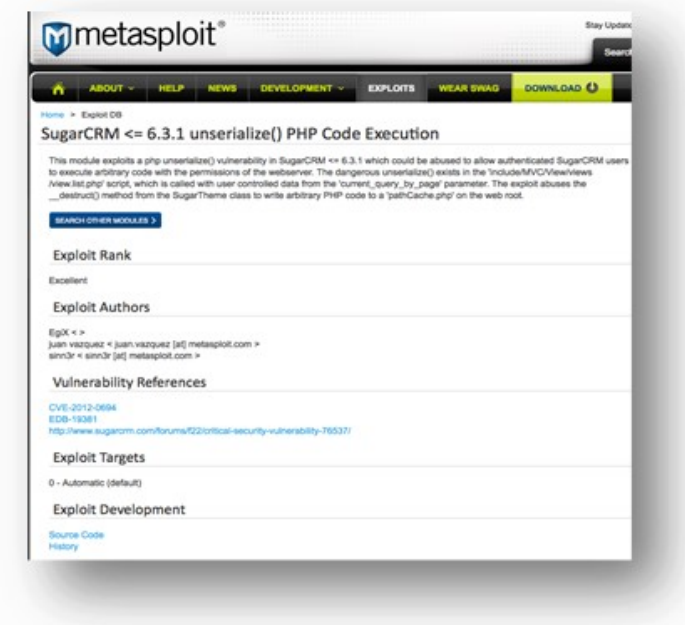


Figura 7. Código de ejecución de y documentación en SugarCRM. Fuente: elaboración propia.

Además de los anteriores, hay costes, posincidente que incluye el cálculo de las pérdidas derivadas (véanse las referencias del Ponemon Institute en el caso de estudio del tema) y también el coste de la reconstrucción de los sistemas. Esta reconstrucción, dependiendo del efecto del incidente puede ser tan simple como una

© Universidad Internacional de La Rioja (UNIR)

reinstalación o reparación de un software, pero en ocasiones puede ser tan costosa como el requerir servicios profesionales para recuperar datos dañados. En otras ocasiones, y de manera discutible, la reparación se complementa con un contraataque o persecución de los intrusos.

© Universidad Internacional de La Rioja (UNIR)

1.5. La seguridad es un proceso

La seguridad no es un producto, algo que se pueda conseguir y una vez terminado, se tiene. Por el contrario, la seguridad son actividades continuas realizadas dentro de un plan sistemático que debe evaluarse continuamente. Es decir, **la seguridad de la información es un proceso. Los** elementos fundamentales de ese proceso son los activos de información, por eso la base de todo el proceso es su identificación, para después aplicar una serie de herramientas de gestión.

La gestión de la seguridad implica la **identificación de activos de información** y el desarrollo, documentación e implementación de **políticas, normas, procedimientos y directrices** que garanticen su disponibilidad, integridad y confidencialidad.

Las **herramientas de gestión** (como la clasificación de datos, la formación y concienciación sobre seguridad, la evaluación de riesgos y el análisis de riesgos) se utilizan para identificar las amenazas, clasificar los activos y su vulnerabilidad para establecer **controles de seguridad** eficaces.

Es importante distinguir las diferentes herramientas de gestión. En muchas ocasiones se habla de políticas para hacer referencia a diferentes herramientas que se utilizan en diferentes niveles de la gestión. Por ello, es importante hacer una clarificación terminológica.

© Universidad Internacional de La Rioja (UNIR)

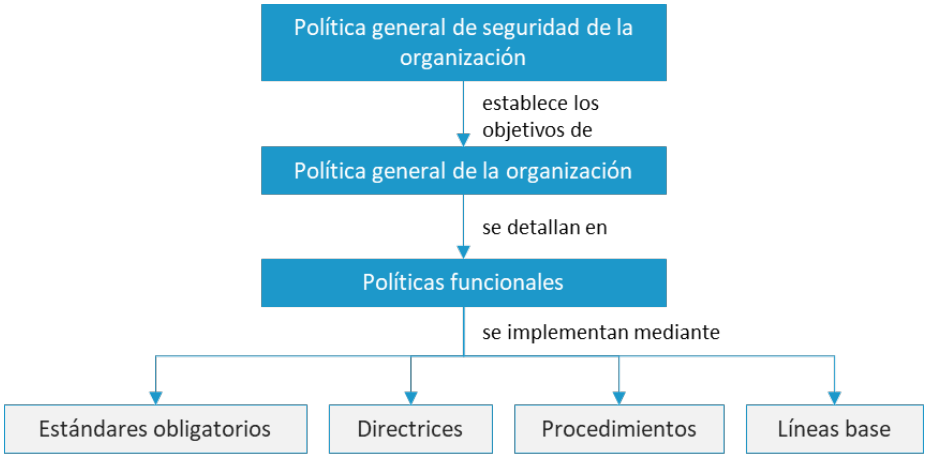


Figura 8. Jerarquía de herramientas y sus relaciones. Fuente: elaboración propia.

A continuación se describen cada una de ellas.

Política general de seguridad

Esta es una política general de alto nivel y de carácter estratégico de la que se derivan las demás. Típicamente contiene lo siguiente:

- Una declaración de la importancia de los recursos de información en la empresa.
- Una declaración de compromiso de la dirección clara con la seguridad de la información.
- Un compromiso de delegación a las políticas derivadas de ella.

Políticas funcionales

Estas políticas son también de alto nivel, por lo que indican qué debe hacerse, pero no detallan el cómo (esto vendrá detallado concretamente en los procedimientos). Típicamente, estas políticas afectan a un área funcional o un determinado tipo de aplicación, como puede ser la política de uso del correo electrónico.

© Universidad Internacional de La Rioja (UNIR)

Estándares, directrices y procedimientos

Los estándares, directrices y procedimientos son **medios para implementar las políticas.**

Los **estándares** especifican el uso de ciertas tecnologías o métodos de un modo uniforme. Son obligatorios y en ocasiones implican determinados compromisos con ciertos sistemas operativos o fabricantes de software.

Las **directrices** son similares a los estándares, pero son solo recomendaciones, no son de obligado cumplimiento. Son un mecanismo más flexible que pueden utilizarse para determinar estándares.

Los **procedimientos** (a veces denominados prácticas) son descripciones detalladas de los pasos para llevar a cabo una determinada tarea para que los usuarios los puedan llevar a cabo sin dudas.

También mencionamos las **líneas base** *(baselines)* que son descripciones sobre cómo configurar determinados elementos de seguridad para que sean aplicados de manera uniforme en toda la organización.

© Universidad Internacional de La Rioja (UNIR)

Para comprender las diferencias, la siguiente tabla recoge un ejemplo concreto:

Política	Los responsables deben proveer un entorno de procesamiento seguro en el que se mantenga la seguridad de la información.
Estándar	Los responsables deben utilizar la solución de antivirus de McAfee en todos los equipos de usuario.
Directriz	Los usuarios de equipos deben atender a una sesión on-line de formación sobre el uso de antivirus y su importancia.
Procedimiento	Todos los usuarios de equipos deben establecer la actualización del antivirus corporativo con periodicidad semanal. Los pasos por seguir son los siguientes: [...]
Línea base	La configuración del antivirus de McAfee por defecto en los ordenadores debe establecerse de acuerdo con los siguientes parámetros: [...]

Tabla 2. Ejemplo de las diferencias entre políticas, estándares, directrices, procedimientos y líneas base. Fuente: elaboración propia.

En el ejemplo anterior, la política es aún de un nivel general. Es frecuente tener políticas más específicas para cada tipo de aplicación a utilizar en la organización.

Por último, es importante recalcar que, aunque la nomenclatura varía de una entidad a otra, la jerarquía siempre se debe tener tres niveles bien diferenciados. En primer lugar, una ¡nivel estratégico que defina las líneas generales, a continuación, el nivel táctico que profundice y complete las políticas y finalmente el nivel operativo que establezca como implementar y cumplir los niveles superiores.

© Universidad Internacional de La Rioja (UNIR)

1.6. La clasificación de la información

No toda la información en la organización es igualmente valiosa. Por ejemplo, los secretos industriales como la fórmula de fabricación de un producto afectan a la propia ventaja competitiva y razón de ser de muchas empresas. Su revelación a terceros simplemente puede terminar con la organización. Algo parecido ocurre con la información sobre la estrategia de nuevos productos de una empresa, esa información es el objeto más preciado del espionaje industrial.

Dado que la protección de la información cuesta dinero, **clasificarla** permite dedicar más dinero a los recursos más valiosos.

En el entorno militar y el sector público, la clasificación de la información tiene una larga historia. No obstante, es útil para cualquier organización, bien como mecanismo de análisis o para evaluar qué información está afectada por determinadas protecciones legales.

La clasificación de la información permite identificar el valor de los recursos de información, incluyendo la información más sensible o vital para la empresa.

Clasificar la información además demuestra un compromiso con la seguridad y puede ser imprescindible debido a regulaciones existentes.

Niveles de clasificación

La clasificación suele hacerse en función de una serie de niveles. La siguiente tabla resume una tipología habitual en los documentos en el entorno del gobierno.

© Universidad Internacional de La Rioja (UNIR)

Tipo	Definición
Sin clasificar	Información no clasificada como sensible o clasificada. Por definición, la difusión de esta información no afecta a la confidencialidad.
Sensible pero no clasificada	Información que tiene un impacto menor si se difunde.
Confidencial	La información que de ser difundida puede causar daño a la seguridad nacional.
Secreta	Su difusión causaría un daño importante.
Alto secreto	Su difusión causaría un daño extremadamente grave.

Tabla 3. Clasificación de documentos en un entorno gubernamental. Fuente: elaboración propia.

En el entorno de las empresas se utilizan otro tipo de clasificaciones. La siguiente tabla proporciona un ejemplo.

Tipo	Definición
Uso público	Puede difundirse públicamente.
Uso interno	Información que puede difundir internamente pero no externamente. Por ejemplo, información sobre los proveedores y su eficiencia.
Confidencial	La información más sensible. Por ejemplo, información sobre fórmulas de productos, productos nuevos o fusiones empresariales en curso.

Tabla 4. Clasificación de documentos en un entorno empresarial. Fuente: elaboración propia.

La anterior clasificación tiene que ver con el **impacto en la empresa globalmente,** pero hay otra categoría, la de la **información personal,** cuya difusión está protegida por la ley dado que afecta a los derechos de los individuos. Por ejemplo, el sueldo de un empleado o la información médica sobre el mismo.

Además de los criterios de impacto en su difusión que acabamos de ver, la edad de la información suele ser también un criterio, los documentos de defensa normalmente se desclasifican tras un cierto tiempo, y una fórmula de un producto antiguo probablemente ya no tenga el mismo valor si se ha imitado con el tiempo por los

© Universidad Internacional de La Rioja (UNIR)

competidores.

Roles y procedimientos en la clasificación

La clasificación de la información requiere unos roles bien definidos y una serie de pasos o actividades sistemáticas.

Los roles principales son los siguientes:

- **Propietario** *(owner)* **del activo:** el propietario es el **encargado de la protección de los recursos de información.** Establece la criticidad de la información de acuerdo con las políticas de clasificación aprobadas y delega las tareas rutinarias al responsable.

- **Responsable** *(custodian):* normalmente es **personal técnico,** en quien el propietario delega la custodia efectiva de la información. Esto incluye la gestión de las copias de seguridad y cualquier otra tarea técnica necesaria.

- **Usuario:** son los **consumidores de la información** en su trabajo diario. Los principios fundamentales para este rol son los siguientes:

- La información y los recursos **deben utilizarse para la organización,** nunca para usos personales.

- Son **responsables de la gestión de la información que utilizan** durante su trabajo. Particularmente, tienen que cuidar que esa información no quede a la vista. Un ejemplo es cerrar con *password* su terminal si abandonan temporalmente su puesto.

- Deben **comprender y aplicar las políticas y procedimientos de seguridad** de la organización.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Las actividades de clasificación pueden resumirse en las siguientes:

- Identificar los roles mencionados.
- Especificar los criterios de clasificación.
- Clasificar los datos por su propietario.
- Especificar y documentar cualquier excepción a la política de clasificación.
- Especificar los controles que se aplican a cada nivel de clasificación.
- Especificar los procedimientos de terminación para la desclasificación de la información o para la transferencia de custodia de la información a otra entidad.
- Crear un programa de concienciación empresarial sobre la clasificación y sus controles asociados.

© Universidad Internacional de La Rioja (UNIR)

1.7. La seguridad se articula con controles de seguridad

Toda la gestión de la seguridad de la información gira en torno de la identificación de amenazas potenciales, es decir, de riesgos. Se trata de establecer mecanismos para reducir su probabilidad de ocurrencia (en el sentido de posibilidad) o bien para disminuir su impacto en caso de que finalmente la amenaza se materialice.

El control de seguridad tiene como objetivo reducir los efectos de una amenaza o vulnerabilidad de la seguridad.

El establecimiento de un control de seguridad es consecuencia de un **estudio previo** del impacto de determinadas vulnerabilidades o amenazas. El proceso estructurado que produce estimaciones de las pérdidas por esas vulnerabilidades es el **análisis de riesgos** *(Risk Assessment).*

Los conceptos de riesgo son la vara de medir para determinar si un control está bien implementado o no. Por ejemplo, consideremos el siguiente control mencionado en la norma ISO 27001:2013:

- **Objetivo de control:** responsabilidades del usuario
- **Control o medida de ejemplo:** uso de clave control: Se debe requerir que los usuarios sigan buenas prácticas de seguridad en la selección y uso de claves.

El riesgo en este caso redundaría en la pérdida de confidencialidad (y también de integridad y/o disponibilidad, ya que la obtención de claves de usuarios puede permitir a un intruso entrar en los sistemas y modificarlos).

La organización debe implementar este **control en la forma de políticas** (filosofía general sobre las claves) **y** en **procedimientos** concretos (por ejemplo, cambios de

© Universidad Internacional de La Rioja (UNIR)

contraseña cada seis meses y uso de un comprobador de fortaleza de las contraseñas).

Esas medidas concretas, en este caso, permiten reducir la probabilidad de que un intruso sea capaz de adivinar una clave y en el caso de que lo consiga, que su efecto (impacto) sea temporal. No obstante, no permitirán eliminar el riesgo completamente, dado que un ataque de ingeniería social puede engañar a un usuario para dar la clave a un software malicioso (este sería el caso del *phishing*).

© Universidad Internacional de La Rioja (UNIR)

1.8. La seguridad en la información implica la gestión de los riesgos

Todo el mundo tiene una noción intuitiva de qué es un riesgo. **Asumir un riesgo es equivalente a hacer una elección,** dado que siempre que actuamos elegimos hacer algo en lugar de dedicar nuestro tiempo y recursos a otras cosas.

En el dominio de la seguridad de la información los riesgos están asociados a **eventos no deseados,** por ejemplo, el riesgo de tener un ataque de un cierto tipo y como consecuencia sufrir un robo de datos personales.

No obstante, para poder **medir con una cierta fiabilidad** el impacto y la posibilidad de que un evento no deseado suceda hay primero que **analizar los elementos que componen el riesgo y sus relaciones.** Una vez un riesgo ha sido analizado y evaluado, hay varias opciones. Se puede aceptar tal cual, tratar de tomar alguna medida para mitigarlo en su impacto o en su probabilidad de ocurrencia o bien si fuera posible evitarlo o eliminarlo completamente.

Hay una cuarta vía para la gestión del riesgo que realmente no actúa sobre el riesgo en sí. Esta es la opción de **transferir el riesgo,** es decir, de recurrir a algún tipo de **seguro** para que, en caso de ocurrencia del evento no deseado, haya una compensación económica.

Al conjunto de procesos de análisis, evaluación y planificación del riesgo se le denomina **gestión de riesgos.**

La gestión de riesgos en la seguridad informática es especialmente complicada por la dificultad de estimar los riesgos. Bruce Schenier lo identifica en su artículo «Does Risk Management make Sense?». Puede consultarse aquí: http://www.schneier.com/essay-240.html

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

© Universidad Internacional de La Rioja (UNIR)

1.9. La seguridad es tanto física como lógica

El dominio de la seguridad abarca todo aquello en el entorno de los sistemas de información que puede tener un **impacto en la disponibilidad, integridad y confidencialidad** de la información. Un desastre natural es un ejemplo de una amenaza física. Las medidas son también de una variedad muy diversa, como los circuitos cerrados de televigilancia.

A pesar de que este dominio de la seguridad de la información puede parecer el más alejado de la profesión en sí, es importante entenderlo, ya que el *firewall* mejor configurado no podrá aguantar si alguien es capaz de acceder físicamente a la máquina que lo ejecuta.

© Universidad Internacional de La Rioja (UNIR)

Instalación con medidas bien diseñadas de seguridad física

El búnker de la empresa Bahnhof, que cuenta con Wikileaks como uno de sus clientes más famosos. Aunque el construir un centro de datos en un búnker parece a muchos analistas más una operación de marketing que una necesidad física, sus características son interesantes para ilustrar el diseño conjunto físico-lógico de sistemas seguros.

Entre los aspectos que sus creadores tuvieron en cuenta fueron la estabilidad geológica y el aislamiento frente a ataques físicos externos. No obstante, dado que uno de los mayores riesgos físicos es el acceso no autorizado, en ese aspecto la ubicación del centro no aporta ningún beneficio adicional.



Figura 9. Instalaciones del proveedor de servicios sueco Bahnhof situado en un antiguo búnker de la Segunda Guerra Mundial en las montañas cerca de Estocolmo. Fuente: Europea press, 2010.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Donn B. Parker, en su libro *La lucha contra los delitos informáticos*, ha recopilado una lista muy completa que él llama las siete **principales fuentes de pérdidas físicas,** el siguiente es un resumen con ejemplos:

- **Temperatura:** variaciones extremas de la temperatura, por ejemplo, en un incendio.
- **Gases:** gases de guerra como el gas Sarin, pero también gases industriales o partículas en suspensión.
- **Líquidos:** agua de una inundación, líquidos utilizados en la limpieza.
- **Organismos:** virus, bacterias o insectos, por ejemplo. Pero también las personas.
- **Proyectiles:** desde meteoritos a balas o explosiones.
- **Movimientos:** caídas o terremotos.
- **Anomalías en la electricidad:** magnetismo, radiaciones, etc.

Los controles de seguridad física son tan diversos como las amenazas. Las áreas fundamentales que deben considerarse pueden resumirse en las que se presentan a continuación.

Controles administrativos

Incluyen todos los **procedimientos administrativos** (en oposición a los controles propiamente físicos o técnicos).

Podemos mencionar los siguientes como aspectos fundamentales:

- Planificación de los requisitos de las instalaciones.
- Gestión de la seguridad de las instalaciones.
- Controles administrativos al personal.

© Universidad Internacional de La Rioja (UNIR)

Controles del entorno y de la habitabilidad

Son los controles físicos esenciales para **mantener la operación de los sistemas y del personal que los opera.** Las siguientes son las áreas principales:

- Suministro eléctrico.
- Detección y supresión de incendios.
- Calefacción, ventilación y aire acondicionado.

Controles técnicos y físicos

En este apartado agrupamos **controles que no son puramente administrativos** (a pesar de tener aspectos administrativos). Las principales áreas son las siguientes:

- Control del inventario de equipos. Esencialmente, el control del robo y el daño a los equipos.
- Dispositivos de control de acceso a las instalaciones.
- Control de las condiciones de las instalaciones.
- Detección de intrusos y alarmas.
- Requisitos de los medios de almacenamiento.

© Universidad Internacional de La Rioja (UNIR)

1.10. La seguridad implica a las personas

Una percepción falsa relativamente extendida es la de que el mantenimiento de los sistemas en cuanto al sistema operativo, software de red y aplicaciones, junto a sistemas defensivos y políticas de seguridad escritas proporcionan un nivel adecuado de seguridad. La realidad es que el **elemento más débil** del sistema de seguridad es en muchos casos el **factor humano.**

La ingeniería social es la práctica y los métodos para obtener información confidencial a través de la manipulación de usuarios legítimos.

Es importante entender que el **factor humano es un elemento más del sistema de información** y como tal las políticas y las herramientas para implementarlas deben tenerlos en cuenta.

© Universidad Internacional de La Rioja (UNIR)

1.11. Referencias bibliográficas.

Schneier, B. (2000). Prefacio. *Secrets & Lies.* Jhon Wiley Computer Publishing. https://www.schneier.com/books/secrets-and-lies-pref/

Europa press. (2010, agosto 31). Los servidores de Wikileaks se alojarán en un búnker nuclear de Estocolmo. *A B C* . https://www.abc.es/tecnologia/servidores-wikileaks-201008310000_noticia.html

International Organization for Standardization. (2013). Information technology — Security techniques — Information security management systems — Requirements (estándar ISO 27001:2013). https://www.iso.org/standard/54534.html

Mizzi, A. (2010). Return on Information Security Investment – The Viability Of An Anti-Spam Solution In a Wireless Environment. *International Journal of Network Security, 10*(1), 18-24. https://citeseerx.ist.psu.edu/viewdoc/download?doi=10.1.1.302.8763&rep=rep1&type=pdf

© Universidad Internacional de La Rioja (UNIR)

Economía de la seguridad de la información

Anderson, R. y Moore, T. (2008). Information Security Economics – and Beyond. En Řiha, Z. y Racková, E. (2008) *Information Security Summit 2008 – Towards an Electronic Society.* 1.° ed. Praha: Tate International, p. 1-26. https://www.cl.cam.ac.uk/~rja14/Papers/econ_czech.pdf

En este artículo, los autores Ross Anderson y Tyler Moore hacen una revisión del área de «Information Security Economics», destacando el balance entre los aspectos técnicos y los que no lo son, como los incentivos o las externalidades, que provienen de la ciencia económica e incluso de la sociología o la psicología. También se revisa el rol de los gobiernos en la seguridad de la información. El artículo solamente menciona los principales elementos y proporciona ejemplos y referencias para profundizar.

© Universidad Internacional de La Rioja (UNIR)

Social Engineering Fundamentals

Granger, S. (18 de diciembre de 2001). *Social Engineering Fundamentals, Part I: Hacker Tactics.* Broadcom. https://community.broadcom.com/symantecenterprise/communities/community-home/librarydocuments/viewdocument?DocumentKey=891b1f29-e2e7-4484-89c0-a2137ee82f8b&CommunityKey=1ecf5f55-9545-44d6-b0f4-4e4a7f5f5e68&tab=librarydocuments

Compilación de terminología y técnicas de ingeniería social y principios básicos para defenderse de ellas.

© Universidad Internacional de La Rioja (UNIR)

¿Por qué la seguridad de la información es difícil?

Anderson, R. (diciembre de 2001). *Why Information Security is Hard – An Economic Perspective* [Presentación en Conferencia]. 17th Annual Computer Security Applications Conference (ACSAC'01), IEEE Computer Society. https://www.cl.cam.ac.uk/~rja14/Papers/econ.pdf

El artículo de Anderson del 2001 mostró cómo el análisis económico explica muchos fenómenos que los investigadores de seguridad habían encontrado hasta entonces sin poder explicar por qué sucedían. Por ejemplo, ¿por qué el software como Windows contiene errores de seguridad que afectan a tanta gente? Aunque es un artículo un tanto antiguo, puede considerarse como el primero que abordó de manera sistemática el análisis económico de la seguridad de la información.

© Universidad Internacional de La Rioja (UNIR)

Historia secreta de los primeros hackers – informática

Documentales ST. (21 de abril de 2014). *Historia secreta de los primeros hackers – Informática [Documental]* [Vídeo]. YouTube. https://www.youtube.com/watch?v=dQCxA9XyUW4

Este vídeo del Discovery Channel hace un relato histórico de los primeros hackers informáticos desde sus precursores, los *phreakers* del sistema telefónico. El vídeo es interesante porque menciona los orígenes de la «ingeniería social» con el sistema de operadores telefónicos.

NOTA: La traducción tiene algunos términos que pueden inducir a confusión. Por ejemplo, hacker se traduce en el vídeo por «pirata informático», lo cual no encaja bien con el uso de este último término en español.

© Universidad Internacional de La Rioja (UNIR)

1. Indica cuál de las siguientes afirmaciones es correcta respecto a la seguridad de la información:

A. Los procedimientos detallan a alto nivel los pasos que deben seguirse para implementar las políticas.

B. Las directrices establecen normas de obligado cumplimiento sobre la configuración de distintos elementos del sistema.

C. Una línea base puede servir para complementar un estándar con información adicional.

D. Las políticas detallan los elementos software que la organización debería utilizar para cubrir objetivos de control de seguridad de la información.

2. Indica cuál de las siguientes afirmaciones es correcta respecto a la seguridad de la información:

A. El custodio protege la información teniendo en cuenta el esquema de clasificación asignado por el propietario.

B. El propietario implementa el esquema de clasificación por órdenes del responsable.

C. El responsable define la clasificación y los usuarios la implementan valorando el tipo de información que manejan.

D. No hay ningún caso posible en el que los roles de elaborador, custodio, propietario y usuario recaigan todos en la misma persona.

© Universidad Internacional de La Rioja (UNIR)

3. Indica cuál de las siguientes afirmaciones es verdadera:

A. Las intrusiones en los sistemas informáticos afectan a la confidencialidad de la información exclusivamente.

B. Las prácticas de ingeniería social tratan de explotar el factor humano para obtener datos confidenciales.

C. La privacidad de los datos personales sensibles es el objetivo de mantener la confidencialidad.

D. La clasificación de la información tiene como objeto establecer niveles de disponibilidad de la información.

4. Indica cuál de las siguientes opciones no es una posible vía para gestionar un riesgo de seguridad de la información:

A. Contratar un seguro con una aseguradora que cubra la eventualidad de una pérdida de datos.

B. Establecer controles sobre la forma en que los usuarios gestionan sus claves, por ejemplo, obligándolos a cambiarlas cada cierto tiempo.

C. Cesando la ejecución de determinadas tareas que suponen riesgos de seguridad para la organización.

D. Asumir el riesgo cuando los costes de hacerlo son pequeños.

© Universidad Internacional de La Rioja (UNIR)

5. Indica cuál de las siguientes afirmaciones es cierta:

A. El costo de ruptura hace referencia al costo que la empresa asume cuando se produce una intrusión.

B. En general, nunca se debe emplear en los recursos destinados a la protección de un activo, más dinero que el costo que la pérdida de este supondría a la organización.

C. Los costos que asumen las empresas ante un incidente de seguridad de la información incluyen únicamente los costos de reparación de vulnerabilidades en el software.

D. Ninguna de las anteriores.

6. Indica cuál de las siguientes afirmaciones es cierta:

A. La colocación de tornos en la entrada de un centro de datos es un ejemplo de medida física de seguridad de la información.

B. La disponibilidad de la información no puede verse comprometida por una fuga de agua.

C. La seguridad física de un sistema de información tiene como ámbito de aplicación de la empresa.

D. Ninguna de las anteriores.

7. Indica cuáles de los siguientes son ejemplos de controles de seguridad:

A. Facilitar el trabajo de los empleados permitiendo el uso de sus dispositivos móviles personales.

B. Obligar a que las contraseñas sean robustas.

C. Analizar el uso de los ficheros en disco de los usuarios para buscar contenido ilegal.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

8. Indica cuál de las siguientes afirmaciones es cierta:

A. La identificación de los usuarios es la autentificación de estos en el sistema.

B. La criptografía permite establecer el almacenamiento seguro, pero no la transferencia de datos segura.

C. El desarrollo de software seguro es más barato para los fabricantes de paquetes de software, dado que reduce el impacto económico de su responsabilidad legal.

D. Ninguna de las anteriores

9. Indica cuál de las siguientes afirmaciones es cierta:

A. La clasificación de la información tiene como objetivo cumplir con los requisitos legales de su difusión.

B. Una información clasificada como confidencial no puede ser reclasificada posteriormente.

C. La clasificación de los recursos de información puede tener excepciones.

D. Ninguna de las anteriores.

10. Indica cuál de las siguientes afirmaciones es cierta:

A. Siempre es más importante reducir la probabilidad que el posible impacto al gestionar riesgos.

B. La probabilidad de un ataque únicamente depende de la motivación económica de los atacantes.

C. El coste de implantar una medida de protección no estará justificado desde el punto de vista de seguridad, si dicha medida no está vinculada a reducir un riesgo asociado.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)